

Güvenlik Kavramları Envanteri: Duruş, İlke, Alan ve Anti-Örüntü Haritası

ÖFY

August 2026

Bu belge, *security-first* ile *security obsession* arasındaki kavramsal ayırmadan başlayarak güvenlik alanının söz varlığının sistematik olarak taranması sonucu oluşturulmuştur. Belge altı eksenle örgütlenmiştir: duruş, ilke, alan, aktör, ölçüm ve anti-örüntü.

Security-First ile Security Obsession Ayrımı

Security-first bir önceliklendirme ilkesidir; *security obsession* ise aynı ilkenin durma koşulunu kaybetmiş hâlidir. Ayrım “ne kadar güvenlik” sorusunda değil, “neye göre ve nereye kadar” sorusunda ortaya çıkar.

Referans Noktası

Security-first bir tehdit modeline dayanır: varlık, saldırgan profili, saldırı yüzeyi ve etki tanımlıdır. Kontroller bu modelden türetilir; model yanlışsa kontrol de değişir.

Obsession ise kaygıya dayanır. Kontroller bir tehdit analizinden değil, “olur da” duygusundan doğar. Model bulunmadığından yanlışlanabilirlik de yoktur: kontrolün gereksiz olduğunu gösterecek bir yöntem mevcut değildir.

Durma Koşulu

Security-first yaklaşımında kabul edilen artık risk (residual risk) açıkça tanımlıdır. “Bu tehdit sınıfını kabul ediyoruz, şu kontrolü koymuyoruz, gerekçesi şudur” biçiminde bilinçli bir kapanış bulunur.

Obsession’da durma koşulu yoktur. Her kontrolün üzerine bir kontrol daha eklenebilir, çünkü “daha güvenli olmak” her zaman mümkündür. Sonuç sonsuz gerilemedir.

Maliyet Muhasebesi

Security-first, güvenliği sonlu bir kaynağın tahsisi olarak görür: mühendislik saati, gecikme, kullanılabilirlik, operasyonel karmaşıklık. Ödünleşim (trade-off) açıkça yapılır.

Obsession güvenliği leksikografik öncelik hâline getirir; güvenlik lehine olan her şey diğer her şeyin önündedir. Bu tutum maliyeti görünmez kılar ancak ortadan kaldırmaz: maliyet başka yerden çıkar.

Yerleşim

Security-first sola kaydırır (shift-left): tasarım kararına, veri modeline, API sözleşmesine gömülür. Yapısaldır, sonradan eklenen bir katman değildir.

Obsession kapı koyar: sürecin sonuna onay, gözden geçirme ve imza aşamaları biriktirir. Yapıyı değiştirmedikten aynı hataları her seferinde yeniden yakalamaya çalışır.

Ölçüm

security-first	->	birim maliyet başına risk azalması
obsession	->	kontrol sayısı, politika sayfası sayısı, reddedilen istek sayısı

İkinci ölçüm seti benimsendiğinde sistem, riski azaltmayan ancak sayılabilir olan kontroller üretmeye başlar; bu, güvenlik gösterisinin (security theater) yapısal nedenidir.

Ayırt Edici Sonuç: Net Negatif Güvenlik

Asıl ayırt edici kriter, obsession'ın belirli bir eşikten sonra güvenliği düşürmesidir.

- Otuz günde bir zorunlu parola rotasyonu, tahmin edilebilir parola dizilerine ve fiziksel not tutmaya yol açar. NIST SP 800-63B bu nedenle ilgili öneriyi geri çekmiştir.
- Her olaya alarm üretmek, alarm yorgunluğuna (alert fatigue) ve gerçek alarmın gürültü içinde kaybolmasına neden olur.
- Aşırı ağır onay süreci gölge BT üretir; ekip süreci bütünüyle atlar ve görünürlük sıfırlanır.
- Statik dokümantasyon sayfasına çok faktörlü kimlik doğrulama uygulamak, kullanıcıya kimlik doğrulamayı bir engel olarak öğretir.

Security-first'te kontrol, korunan varlığın değeriyle orantılıdır. Obsession'da orantı ilişkisi kopmuştur; kontrol kendi başına bir değer hâline gelir.

Epistemik Fark

En keskin ayrım burada belirir. Security-first tartışmaya açıktır: “Bu kontrol hangi tehdidi karşılıyor?” meşru bir sorudur ve cevabı vardır.

Obsession'da aynı soru bir sadakat testine dönüşür; soruyu soran kişi “güvenliği önemsemeyen” konumuna itilir. Teknik bir iddia ahlaki bir tutuma dönüştüğü anda sistem kendini düzeltme yeteneğini kaybeder.

Duruş (Postür) Kavramları

Bu başlık, “güvenliği süreçte nereye koyuyorsun” sorusunun cevaplarını içerir.

- **Secure by design:** Güvenlik mimari kararın kendisindedir; sonradan eklenen katman değildir. CISA ve NCSC’nin son yıllarda öne çıkardığı terimdir.
- **Secure by default:** Ürün kutudan çıktığı hâliyle güvenlidir. Kullanıcı hiçbir işlem yapmazsa en güvenli konfigürasyon geçerlidir; güvenlik opt-in değil, gevşetme opt-out’tur.
- **Shift-left security:** Kontrolün sürecin soluna, geliştirme anına kaydırılması.
- **Shift-right / runtime security:** Üretimde gözlem, tespit ve davranış analizi. Sola kaydırmanın tamamlayıcısıdır, alternatifi değildir.
- **Privacy by design / by default:** Aynı mantığın veri koruma karşılığı. GDPR Madde 25’te yasal dayanağı bulunur.
- **Security as an enabler:** Güvenliğin fren değil, riskli işi mümkün kılan unsur olarak konumlandırılması.
- **Paved road / golden path:** Güvenli yolun aynı zamanda en kolay yol hâline getirilmesi. Yasaklamak yerine doğru olanı düşük sürtünmeli kılmak.
- **Guardrails, not gates:** Otomatik sınırlar koymak, manuel onay kapısı kurmamak.

Klasik Tasarım İlkeleri

Saltzer ve Schroeder’in 1975 tarihli sekiz ilkesi alanın omurgasını oluşturmaya devam etmektedir.

Economy of mechanism	-> basit tut, denetlenebilir olsun
Fail-safe defaults	-> varsayılan "reddet", istisna "izin ver"
Complete mediation	-> her erişim her seferinde kontrol edilsin
Open design	-> güvenlik sırra değil anahtara dayansın
Separation of privilege	-> tek koşul yetmesin (iki anahtar)
Least privilege	-> asgari yetki
Least common mechanism	-> paylaşılan bileşeni azalt
Psychological acceptability	-> kullanıcı bypass etmek zorunda kalmasin

Son madde özel önem taşır; obsession’ın ihlallerinin büyük bölümü bu ilkede yoğunlaşır.

Sonradan Eklenen İlkeler

- **Defense in depth:** Katmanlı savunma; tek kontrolün delinmesi sistemi düşürmemelidir.
- **Zero trust:** Konuma dayalı örtük güven yoktur; her istek kimlik ve bağlam ile doğrulanır (“never trust, always verify”).
- **Assume breach:** İhlalin olmayacağı değil, olduğu varsayımıyla tasarlamak. Blast radius küçültme, segmentasyon ve tespit süresi odaklıdır.
- **Blast radius containment:** Bir bileşen düştüğünde etki alanının sınırlı kalması.
- **Least astonishment:** Güvenlik davranışının kullanıcıyı şaşırtmaması.
- **Attack surface reduction:** En güvenli kod, yazılmayan koddur.
- **Fail closed / fail open:** Hata anında hangi tarafa düşüleceğinin bilinçli seçimi. Yetkilendirme fail-closed, itfaiye kapısı fail-open olmalıdır.
- **Separation of duties:** Tek kişinin bir işlemi baştan sona yapamaması.
- **Policy as code:** Complete mediation ilkesinin modern hâli; yetki kararının merkezi, versiyonlu ve test edilebilir olması.
- **Crypto agility:** Algoritmanın değiştirilebilir olması; post-kuantum geçişinin ön koşuludur.
- **Sustainable security / security debt:** Güvenliğin sürdürülebilirliği ve teknik borcun güvenlik karşılığı.

Anti-Örüntüler

- **Security theater:** Riski azaltmayan ancak görünür olan kontrol. Schneier’in terimidir.
- **Security by obscurity:** Gizliliğe dayalı güvenlik; Kerckhoffs ilkesinin ihlali.
- **Checkbox / compliance-driven security:** Hedefin risk azaltmak değil denetimden geçmek olması.
- **Bolt-on security:** Bitmiş sisteme sonradan cıvatalanan güvenlik.
- **The department of “no”:** Güvenlik ekibinin varsayılan cevabının olumsuz olması; gölge BT üretir.
- **Alert fatigue / normalization of deviance:** Uyarıların gürültüye, ihlallerin rutine dönüşmesi.

- **Perimeter fallacy (M&M security):** Dışı sert, içi yumuşak mimari. Zero trust tam olarak buna verilen cevaptır.
- **Cargo cult security:** Büyük ölçekli bir kurumun kontrolünü tehdit modeli olmaksızın kopyalamak.

Spektrumdaki Konum

ihmal	---	pragmatik	---	security-first	---	obsession	---	felç
		(risk kabul)		(model + durma koşulu var)		(durma koşulu yok)		(net negatif güvenlik)

Sıkça karıştırılan bir çift de burada anılmalıdır: *risk-based security* etki ile olasılığın çarpımı üzerinden önceliklendirme yapar; *threat-informed defense* ise gerçek saldırgan davranışından (örneğin MITRE ATT&CK) türetilir. Birincisi soyut, ikincisi ampiriktir; pratikte birlikte kullanılırlar.

Tehdit Modelleme ve Saldırgan Perspektifi

- **STRIDE:** Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege. Microsoft'un tehdit taksonomisidir.
- **DREAD:** Etki puanlama yöntemi; öznellik nedeniyle büyük ölçüde terk edilmiştir.
- **PASTA / LINDDUN:** Sırasıyla süreç odaklı ve mahremiyet odaklı tehdit modelleme alternatifleri.
- **Kill chain (Lockheed Martin):** Recon, weaponization, delivery, exploitation, installation, command and control, actions on objectives. Savunmanın zincirin hangi halkasında kesileceğinin seçimini sağlar.
- **MITRE ATT&CK:** Gerçek saldırgan taktik ve tekniklerinin ampirik matrisi.
- **Attack tree (Schneier):** Kök hedefi alt saldırı yollarına ayıran ağaç yapısı.
- **Adversarial mindset / red team:** "Nasıl çalışır" yerine "nasıl kırılır" sorusu.
- **Purple team:** Saldırı ve savunmanın ayrı takımlar değil, tek geri besleme döngüsü olması.
- **Cyber deception:** Honeypot, honeypot, canary token. Saldırganın maliyetini ve gürültüsünü artırır.

Pyramid of Pain

Bianco'nun modeli, hangi göstergenin bloklanmasının saldırıya ne kadara mal olduğunu gösterir.

TTPs	<- en acı verici (davranış değişimi gerekir)
Tools	
Network / Host Artifacts	
Domain Names	
IP Addresses	
Hash Values	<- en kolay (saniyeler içinde değiştirilir)

Güvenlik Ekonomisi

Bu alan görece az tartışılır; ancak obsession tartışmasının asıl teorik zemini buradadır.

- **Work factor / cost to attack:** Güvenlik mutlak değildir; saldırının maliyetini savunanın kazancının üzerine çıkarma meselesidir.
- **Gordon–Loeb modeli:** Optimal güvenlik yatırımının beklenen kayıptan küçük olduğunu gösteren ekonomik model; kabaca kaybın yüzde otuz yedisini aşmaması gerektiğini öngörür.
- **Market for lemons:** Akerlof'un modelinin güvenliğe uyarlanması. Alıcı güvenlik kalitesini gözlemleyemediğinden piyasa düşük kaliteye yakınsar.
- **Externality problemi:** Güvensizliğin maliyetini üreticinin değil üçüncü tarafın ödemesi. Yazılım sorumluluğu (liability) tartışmasının kaynağıdır.
- **Moral hazard:** Siber sigortanın savunma yatırımını azaltması.
- **Tragedy of the commons:** Ortak altyapının (DNS, BGP, açık kaynak bağımlılıkları) kimse tarafından yamalanmaması.
- **Weakest link vs. sum of efforts (Varian):** Bazı sistemlerde güvenlik en zayıf halkaya, bazılarında toplam çabaya bağlıdır; yatırım stratejisi buna göre değişir.

Tedarik Zinciri ve Bütünlük

- **SBOM:** Software Bill of Materials; bileşen envanteri. Log4Shell sonrası zorunlu hâle gelen pratiktir.
- **SLSA:** Supply-chain Levels for Software Artifacts; derleme bütünlüğü seviyeleri.
- **Reproducible builds:** Aynı kaynaktan bit düzeyinde aynı çıktı; derleyici arkasından enjeksiyonu tespit eder.

- **Trusting Trust (Thompson, 1984):** Derleyicinin kendisine arka kapı gömülmesi. “Kendi yazmadığın koda güvenemezsin” argümanının klasik kaynağıdır.
- **Provenance / attestation:** Artefaktın kaynağının imzalı kanıtı (Sigstore, in-toto).
- **Typosquatting / dependency confusion:** Paket ekosistemine özgü saldırı sınıfları.
- **Vendoring vs. pinning:** Bağımlılık dondurma stratejileri.
- **Nth-party risk:** Tedarikçinin tedarikçisi; görünürlüğün bittiği nokta.

Kriptografik İlkeler

- **Kerckhoffs ilkesi:** Sistem, anahtar dışında her şey bilinse dahi güvenli olmalıdır.
- **Don’t roll your own crypto:** Modern hâli *misuse-resistant API design*’dır; kütüphane yanlış kullanılmayı zorlaştırmalıdır (libsodium felsefesi).
- **Forward secrecy:** Bugünkü anahtar sızarsa geçmiş trafiğin açılmaması.
- **Post-compromise security / self-healing:** İhlalden sonra güvenliğin kendini toparlaması (Signal Double Ratchet).
- **Harvest now, decrypt later:** Bugün toplanan şifreli verinin kuantum sonrası çözülmesi tehdidi; PQC geçişinin aciliyet gereğesidir.
- **Constant-time implementation:** Zamanlama yan kanalına karşı önlem.
- **Authenticated encryption (AEAD):** Gizlilik ve bütünlüğün ayrılması; “encrypt-then-MAC” tartışmasının kapanışı.
- **Key rotation / key hierarchy / HSM:** Anahtar yaşam döngüsü yönetimi.

Güvence ve Doğrulama

- **Formal verification:** seL4, CompCert gibi matematiksel kanıtla doğrulanmış sistemler.
- **Correct by construction:** Tip sistemi ve dil seçimiyle hata sınıfını imkânsız kılma; Rust’ın bellek güvenliği argümanı.
- **Memory-safe languages:** CISA ve NSA’nın son yıllardaki en somut politika önerisi. İhlallerin yaklaşık yüzde yetmiş bellek güvenliği kaynaklıdır.

- **Fuzzing / property-based testing:** Girdi uzayının rastgele taranmasıyla hata bulma.
- **Common Criteria / EAL seviyeleri:** Resmi güvence sertifikasyonu; ağır ve tartışmalı bir rejimdir.
- **Assurance case / GSN:** Güvenlik iddiasının kanıt ağacıyla desteklenmesi.
- **Bug bounty / coordinated disclosure / VDP:** Dış doğrulama mekanizmaları.

İnsan ve Organizasyon Boyutu

- **Usable security:** Whitten ve Tygar'ın "Why Johnny Can't Encrypt" çalışması alanın kurucu metnidir. Kullanılabilirlik bir güvenlik özelliğidir.
- **Security champion:** Her ekip içinde gömülü güvenlik temsilcisi; merkezi ekibin ölçeklenme çözümüdür.
- **Blameless postmortem:** Suçlama olmaksızın kök neden analizi; bildirim oranını yükselten kültürel mekanizma.
- **Just culture:** Hata ile ihmal arasındaki ayrımın kurumsallaşması.
- **Normalization of deviance:** Vaughan'ın Challenger analizinden; istisnanın kural hâline gelmesi.
- **Swiss cheese model (Reason):** Her katmanın deliği vardır; kaza delikler hizalandığında gerçekleşir.
- **Safety-II / resilience engineering (Hollnagel):** Sistemin nasıl başarısız olduğuna değil, çoğu zaman nasıl başarılı olduğuna bakma.
- **Insider threat:** Kötü niyetli, ihmalkâr ve ele geçirilmiş içeriden kişi ayrımı.
- **Two-person rule / four-eyes principle:** Kritik işlemde ikili onay.
- **Security debt:** Ödenmeyen güvenlik borcunun faiziyle birikmesi.

Tespit ve Müdahale

- **MTTD / MTTR / dwell time:** Tespit süresi, müdahale süresi ve saldırganın sistem içinde kaldığı süre.
- **Detection engineering:** Tespit kurallarının kod gibi versiyonlanması ve test edilmesi.
- **Threat hunting:** Alarm beklemeden proaktif arama.

- **Tabletop exercise / chaos engineering for security:** Planın kâğıt üzerinde değil tatbikatta sınanması.
- **Incident command system:** Olay anında rol netliği.
- **Forensic readiness:** Log ve delilin olaydan önce toplanabilir hâlde olması.
- **Break-glass access:** Acil durumda yetki yükseltmenin denetlenebilir kanalı.
- **Immutable infrastructure / cattle not pets:** Ele geçirilen makineyi onarmak yerine imha etmek.

Erişim ve Kimlik

- **AAA:** Authentication, Authorization, Accounting.
- **RBAC / ABAC / ReBAC:** Rol, öznelik ve ilişki tabanlı yetkilendirme. Google Zanzibar, ReBAC'ın referans mimarisidir.
- **JIT / JEA access:** Tam zamanında ve tam gerektiği kadar yetki; kalıcı ayrıcalığın (standing privilege) tasfiyesi.
- **Privilege escalation path analysis:** Yetki grafiğinde saldırgan yolunun modellenmesi.
- **Capability-based security:** Yetkinin kimliğe değil taşınabilir bir jetona bağlanması; nesne yetenek modeli ve POLA.
- **Confused deputy problem:** Yetkili bir bileşenin yetkisiz istek adına kandırılması. CSRF ve SSRF'in ortak kökenidir.
- **Phishing-resistant MFA:** WebAuthn ve FIDO2; kanal bağlama sayesinde OTP'nin çözemediği sorunu çözer.

Yapay Zekâya Özgü Katman

- **Prompt injection:** Veri düzlemi ile talimat düzleminin ayrılamaması. Klasik SQL injection'ın yapısal analogudur, ancak sanitizasyon çözümü henüz mevcut değildir.
- **Lethal trifecta (Willison):** Özel veri erişimi, güvenilmeyen içerik ve dışa iletişim kanalının bir arada bulunması. Üçü birlikteyse sızıntı kaçınılmazdır.
- **Indirect prompt injection:** Talimatın kullanıcıdan değil, modelin okuduğu dokümandan gelmesi.
- **Model extraction / inversion / membership inference:** Modelden eğitim verisinin veya modelin kendisinin çekilmesi.

- **Data poisoning / backdoor:** Eğitim verisine gömülü tetikleyici.
- **Jailbreak vs. misalignment:** Dışarıdan atlatma ile içsel hedef sapması arasındaki ayrım.
- **Agentic blast radius:** Otonom ajanın yetkisiyle orantılı hasar potansiyeli. En pratik kontrol, insan onayı gerektiren eylem sınıflarının tanımlanmasıdır.
- **OWASP Top 10 for LLM Applications:** Bu alanın konsolide listesi.

Sistem Düzeyi Kavramlar

- **Antifragility (Taleb):** Strese maruz kaldıkça güçlenen sistem; dayanıklılıktan (resilience) farklıdır.
- **Graceful degradation:** Çökme yerine kademeli işlev kaybı.
- **Compartmentalization:** Denizaltı bölmeleri mantığı; sızıntının yayılmasının fiziksel olarak kesilmesi.
- **Air gap:** Stuxnet sonrası kavramın pratikteki sınırlarının görülmesi.
- **Security / usability / cost üçgeni:** Üçünden ikisinin seçilmesi kısıtı.
- **Ashby'nin Gerekli Çeşitlilik Yasası:** Savunmanın çeşitliliği, saldırının çeşitliliğine eşit veya ondan fazla olmalıdır. Sibernetikten güvenliğe doğrudan aktarılabilen tek yasadır.

Son madde security-first ile obsession ayrımına bağlanır: obsession çeşitlilik değil tekrar üretir; aynı kontrolü çoğaltır. Çeşitlilik üretmeyen fazlalık savunma değil, yalnızca maliyettir.

Zafiyet Yaşam Döngüsü

- **CVE / CWE / CVSS / EPSS / KEV:** Sırasıyla tekil zafiyet kaydı, zafiyet sınıfı, teoriye dayalı şiddet skoru, sömürülme olasılığı tahmini ve fiilen sömürülenlerin listesi. CVSS'in tek başına önceliklendirme aracı olarak kullanılması yaygın bir hatadır; EPSS ve KEV tam bu boşluk için geliştirilmiştir.
- **0-day / n-day / forever-day:** Sırasıyla bilinmeyen, yaması mevcut ancak uygulanmamış, ve yaması hiç çıkmayacak zafiyet.
- **Patch gap / exploit window:** Yamanın yayınlanması ile uygulanması arasındaki süre; ihlallerin çoğu bu aralıkta gerçekleşir.
- **Vulnerability vs. exploitability vs. reachability:** Kodda bulunmak, sömürülebilir olmak ve çağrı grafiğinde erişilebilir olmak farklı durumlardır. Reachability analizi SCA gürültüsünü büyük ölçüde azaltabilir.

- **Coordinated disclosure / full disclosure / NOBUS:** Açıklama etiği. Sonuncusu, istihbarat servislerinin “sadece biz sömürebiliriz” gerekçesiyle zafiyeti sakladığı doktrindir.
- **Vulnerability Equities Process:** Devletin bulduğu zafiyeti açıklama veya saklama kararı süreci. EternalBlue ve WannaCry vakası bu tartışmanın kanıtıdır.
- **Patch Tuesday / Exploit Wednesday:** Yamannın tersine mühendislikle silaha dönüştürülme ritmi.

Yönetişim ve Uyum

- **NIST CSF:** Govern, Identify, Protect, Detect, Respond, Recover. En yaygın çerçevedir.
- **ISO 27001 / SOC 2 / PCI-DSS / HIPAA / FedRAMP:** Sertifikasyon ve sektörel rejimler.
- **CIS Controls:** Önceliklendirilmiş ve somut kontrol listesi; çerçevelerin aksine doğrudan uygulanabilir.
- **NIS2 / DORA / Cyber Resilience Act:** Avrupa Birliği’nin yeni nesil zorunluluk rejimi. CRA özellikle önemlidir; yazılım üreticisine ürün sorumluluğu getirmektedir.
- **KVKK / GDPR / veri yerelleştirme:** Mahremiyet rejimleri.
- **Compliance $\neq$ security:** Uyum bir taban olup tavan değildir. Target ve Equifax ihlal anında uyumlu durumdaydı.
- **Control vs. objective vs. evidence:** Denetim üçlüsü. Obsession genellikle üçüncüsünü şişirip birincisini iyileştirmez.
- **Risk appetite / risk tolerance / risk register:** Kurumsal risk dilinin temel üçlüsü.
- **Three lines of defense:** Operasyon, risk fonksiyonu ve iç denetim ayrımı.

Ağ ve Protokol Düzeyi

- **Segmentation / micro-segmentation / east-west traffic:** Yatay hareketin kısıtlanması.
- **Bastion host / jump box:** Yönetim erişiminin tek denetlenebilir kanaldan geçmesi.
- **mTLS ve SPIFFE/SPIRE:** Servisler arası kimlik; zero trust’ın altyapı katmanı.

- **BGP hijacking / RPKI:** İnternetin yönlendirme katmanındaki güven açığı ve kriptografik çözümü.
- **DNSSEC / DoH / DoT:** İsim çözümlemenin bütünlük ve gizlilik katmanları.
- **SSRF ve metadata endpoint:** Bulut ortamında en pahalı tekil zafiyet sınıfı; Capital One ihlali örnektir.
- **Egress filtering:** Çoğu kurumun ihmal ettiği yön. Veri sızıntısı ve komuta-kontrol trafiği buradan geçer.
- **Protocol downgrade / stripping:** Daha zayıf sürüme zorlama saldırıları.
- **Amplification / reflection:** DDoS'un asimetri ekonomisi.

Veri Güvenliği

Veri yaşam döngüsü şu adımlardan oluşur: oluşturma, sınıflandırma, depolama, kullanım, paylaşım, arşivleme ve imha. Son adım en sık atlanandır.

- **Data minimization:** Toplanmayan veri sızdırılmaz. En güçlü ve en az uygulanan kontroldür.
- **Retention policy:** Verinin bir sona erme tarihinin bulunması; hukuki riski azaltır.
- **Tokenization / encryption / hashing / masking:** Sıkça karıştırılan dört farklı dönüşüm.
- **Encryption at rest / in transit / in use:** Sonuncusu için confidential computing, TEE ve enclave teknolojileri.
- **Homomorphic encryption / secure multiparty computation / differential privacy:** Veriyi açmadan işleme ailesi. Differential privacy, veri kümesi düzeyinde matematiksel mahremiyet garantisi sağlar.
- **Crypto-shredding:** Veriyi silmek yerine anahtarını imha etmek; dağıtık sistemlerde unutulma hakkının pratik uygulaması.
- **Re-identification risk:** Anonimleştirmenin çoğu zaman anonim olması. Netflix Prize ve AOL vakaları örnektir.
- **DLP:** Veri sızıntısı önleme. Kullanılabilirlik maliyeti yüksek, atlatılması görece kolay klasik örnektir.

Fiziksel, OT ve Donanım Katmanı

- **IT / OT / ICS-SCADA ayrımı:** OT'de öncelik sırası tersine döner; erişilebilirlik, bütünlük ve gizlilik sırası geçerlidir (CIA yerine AIC).
- **Purdue modeli:** Endüstriyel ağların katmanlı referans mimarisi.
- **Safety vs. security:** Biri sistemin dünyaya, diğeri dünyanın sisteme verdiği zararlar ilgilendir. OT ortamında ikisi çakışır.
- **Tamper-evident / tamper-resistant / tamper-responsive:** Fiziksel koruma dereceleri.
- **Secure boot / measured boot / TPM / attestation:** Güven zincirinin donanımda başlaması.
- **Root of trust / chain of trust:** Güvenin bir noktada kökleşmesi zorunluluğu.
- **Side channel:** Zamanlama, güç (DPA), akustik, elektromanyetik, önbellek (Spectre, Meltdown) ve Rowhammer. Soyutlamanın fiziksel sızıntısıdır.
- **Evil maid attack / supply chain interdiction:** Cihaza fiziksel erişimin diğer tüm kontrolleri geçersiz kılması.
- **HSM / secure element / enclave:** Anahtarın hiçbir zaman dışarı çıkmaması ilkesi.

Sıkça Karıştırılan Kavram Çiftleri

Threat	-- tehdit aktörü veya olayı
Vulnerability	-- zafiyet
Risk	-- tehdit x zafiyet x etki
Exposure	-- fiilen erişilebilir olma
Authentication	-- kim olduğun
Authorization	-- ne yapabileceğin
Accounting	-- ne yaptığın
Attestation	-- iddianın kanıtlanabilirliği
Resilience	-- darbeden sonra eski hâle dönme
Robustness	-- darbeye rağmen değişmeme
Antifragility	-- darbeden sonra güçlenme
Redundancy	-- yedeklilik (üçünün de aracı, kendisi değil)
Incident	-- olay
Breach	-- veri ihlali (hukuki tanımı olan alt küme)
Event	-- log satırı
Alert	-- kural tetiklemesi

Ölçme Sorunu

- **Metrik seçimi:** Mean time to patch, kritik varlıklarda MFA yüzdesi ve sömürülebilir-erişilebilir bulgu sayısı risk azaltımına bağlanabilir; kapatılan talep sayısı bağlanamaz.
- **Goodhart yasası:** Ölçü hedef hâline geldiğinde ölçü olmaktan çıkar. Güvenlik metriklerinin kronik hastalığıdır.
- **Base rate fallacy:** Yüzde doksan dokuz doğruluktaki bir tespit sistemi, olayların nadir olduğu ortamda ezici çoğunlukla yanlış alarm üretir. Alarm yorgunluğunun matematiksel temelidir.
- **Survivorship bias:** Yalnızca tespit edilen ihlallerden öğrenmek; tespit edilmemişler veri kümesinde bulunmaz.
- **Absence of evidence:** “Hiç ihlal yaşamadık” ifadesinin, tespit yeteneği bilinmeden anlamsız olması.
- **Security ROI’nin ölçülemezliği:** Gerçekleşmemiş olayın değeri; bütçe tartışmalarının kök nedenidir.
- **FAIR modeli:** Riski parasal olarak niceleyen tek yaygın çerçeve; nitel ısı haritalarına alternatiftir.

Epistemik ve Felsefi Katman

- **Rice teoremi ve durma problemi:** Bir programın önemsiz olmayan her semantik özelliğinin genel olarak karar verilemez olması. “Bu kod güvenli mi” sorusunun neden algoritmik cevabı bulunmadığının kanıtıdır.
- **Negatif iddia problemi:** Güvenlik, varlık değil yokluk iddiasıdır (“sömürülebilir açık yok”). Yokluk iddiaları ampirik olarak doğrulanamaz, yalnızca yanlışlanabilir. Bu nedenle test güven verir, kanıt vermez.
- **Dijkstra:** Test hatalarının varlığını gösterir, yokluğunu asla.
- **Popper’cı asimetri:** Sızma testi bir yanlışlama girişimidir; geçilmesi bir doğrulama değildir.
- **Knightian belirsizlik:** Olasılığı bilinen risk ile olasılığı bilinmeyen belirsizlik ayrımı. 0-day’ler ikinci kategoridedir; risk hesabına girmezler ve tam bu nedenle derinlemesine savunma gerekir.
- **Kendi kendini denetleyen sistemin sınırı:** Bir sistemin kendi güvenliğini kendi araçlarıyla tam olarak denetleyememesi; rootkit’in çekirdek görünürlüğünü ele geçirmesi örnektir.

- **Adversarial vs. stochastic dünya:** Güvenilirlik mühendisliği rastgele arızayla, güvenlik ise optimize eden bir düşmanla uğraşır. Ortalama vaka değil en kötü vaka geçerlidir. Bu, güvenliği kalite mühendisliğinden ayıran en önemli tek farktır.
- **Gözlemcinin sisteme dahil olması:** Logu üreten bileşen ele geçirildiğinde log güvenilirliğini kaybeder. Bu nedenle write-once, append-only ve off-host loglama gerekir.

Son iki madde birlikte ele alındığında ilk sorunun cevabı tamamlanır: ob-session, adversarial dünyanın belirsizliğini stokastik dünyanın araçlarıyla kapatmaya çalışmaktır; sayılabilir kontrol biriktirerek sayılamayan bir riski kapattığını sanmaktır.

Sözcüksel Kalıplar

security-X Kalıbı

security-first	security-aware
security-by-design	security-conscious
security-by-default	security-minded
security-by-obscurity	security-sensitive
security-as-code	security-critical
security-in-depth	security-hardened
security-native	security-cleared
security-centric	security-gated
security-relevant	security-enforcing
security-bearing	security-annotated
security-labeled	security-tagged
security-partitioned	security-isolated
security-scoped	security-vetted
security-accredited	security-certified
security-approved	security-signed
security-attested	security-audited
security-instrumented	security-observable
security-shifted	security-embedded
security-informed	security-driven
security-oriented	security-focused
security-motivated	security-justified
security-constrained	security-bounded
security-degraded	security-compromised

X-first Kalıbı

privacy-first	safety-first	compliance-first
offline-first	mobile-first	API-first
local-first	cloud-first	test-first
design-first	contract-first	schema-first

secure-by-X Kalıbı

secure by design	secure by default
secure by construction	secure by isolation
secure by separation	secure by verification

X-secure Kalıbı

type-secure	memory-secure
crypto-secure	quantum-secure
future-secure	forward-secure
timing-secure	side-channel-secure
tamper-secure	fail-secure

Not: *fail-secure* ile *fail-safe* karşıt anlamlıdır. Kapı, fail-secure yapılandırılarda güç kesildiğinde kilitli kalır; fail-safe yapılandırılarda açılır. Aynı kalıp, farklı öncelik.

X-security Bileşik Alan Adları

application security (AppSec)	product security (ProdSec)
infrastructure security	platform security
cloud security	container security
network security	endpoint security
data security	identity security
supply-chain security	API security
mobile security	firmware security
hardware security	physical security
operational security (OpSec)	information security (InfoSec)
communications security (ComSec)	signals security (SigSec)
transmission security (TransSec)	personnel security (PerSec)
offensive security (OffSec)	defensive security
memory security	runtime security
build security	deployment security
model security / AI security	agent security

security + İsim Bileşikleri

security posture	security debt
security theater	security fatigue
security budget	security baseline
security boundary	security perimeter
security control	security gate
security champion	security review
security hygiene	security ceiling
security floor	security culture
security by committee	security tax

security friction	security overhead
security incident	security event
security clearance	security zone
security domain	security context
security model	security policy
security kernel	security monitor
security assertion	security invariant
security guarantee	security property
security proof	security parameter
security margin	security envelope

X-Sec Kısaltma Ailesi

DevSecOps	SecOps	SecDevOps
AppSec	ProdSec	InfoSec
OpSec	NetSec	CloudSec
DataSec	OffSec	PhySec
ComSec	PerSec	SigSec

Anti-Örüntü Kalıpları

security theater	security by obscurity
security by committee	security by decree
security by paperwork	security by checkbox
security as a blocker	security as an afterthought
bolt-on security	checkbox security
cargo-cult security	compliance-driven security
performative security	vanity security

Derece Belirten Sıfat Bileşikleri

adequate security	proportionate security
defensible security	pragmatic security
sustainable security	adaptive security
holistic security	layered security
absolute security	(mevcut olmayan referans nokta)
paranoid security	obsessive security
brittle security	illusory security

Tek Sözcüklü Spektrum

paranoia	-> aşırı uç
vigilance	-> sağlıklı hâli
diligence	-> disiplinli hâli
complacency	-> gevşemiş hâli
negligence	-> ihmal
recklessness	-> bilinçli ihmal

resistant / hardened / tolerant Ailesi

phishing-resistant	injection-resistant
tamper-resistant	misuse-resistant
replay-resistant	collision-resistant
censorship-resistant	coercion-resistant
attack-resistant	reverse-engineering-resistant

fault-tolerant	Byzantine-fault-tolerant
intrusion-tolerant	failure-tolerant

memory-hardened	kernel-hardened
container-hardened	image-hardened

proof / free Ekleri

tamper-proof	bullet-proof
injection-proof	future-proof
idiot-proof	(usable security'nin argo hâli)

vulnerability-free	side-effect-free
key-free	password-free
passwordless	agentless

aware / blind Çifti

security-aware	security-blind
risk-aware	risk-blind
threat-aware	threat-agnostic
context-aware	context-free
policy-aware	tenant-aware

zero-X Ailesi

zero trust	zero knowledge
zero standing privilege	zero-day
zero-touch provisioning	zero-copy
zero-retention	zero-log

least / minimal Ailesi

least privilege	least authority (POLA)
least astonishment	least common mechanism
minimal attack surface	minimal trust
minimal disclosure	need-to-know
need-to-share	(9/11 sonrası karşı-ilke)

Güven (Trust) Eksenı

trusted computing base (TCB)	trust anchor
trust boundary	trust domain
trust zone	trust store
web of trust	chain of trust
root of trust	transitive trust
implicit trust	verified trust
trustless	trust-minimized
untrusted input	semi-trusted

Savunma ve Saldırı Kalıpları

defense in depth	defense in breadth
active defense	passive defense
adaptive defense	layered defense
threat-informed defense	forward defense
persistent engagement	defend forward
attack surface	attack vector
attack path	attack chain
attack graph	attack tree
attack simulation	adversary emulation

Risk Kalıpları

risk-based	risk-informed
risk-adjusted	risk-weighted
risk appetite	risk tolerance
risk acceptance	risk transfer
risk register	residual risk
inherent risk	aggregate risk
concentration risk	tail risk
systemic risk	third-party risk

Posture / Hygiene / Maturity Kalıpları

security posture	posture management
CSPM / KSPM / DSPM / SSPM / ASPM	
cyber hygiene	patch hygiene
credential hygiene	dependency hygiene
security maturity	maturity model (BSIMM, SAMM)
capability maturity	control maturity

Maliyet Sözcükleri

alert fatigue	security fatigue
consent fatigue	MFA fatigue (aynı zamanda bir saldırı adı)

review fatigue

security debt	compliance debt
security tax	complexity tax
friction budget	error budget
toil	(SRE'den uyarlanmış)

Breach ve Compromise Dili

assume breach	breach containment
blast radius	lateral movement
dwelt time	time to detect
kill switch	kill chain
compromise assessment	post-compromise security
indicator of compromise (IoC)	
indicator of attack (IoA)	

Meta Kalıplar

security of security	(denetim aracının kendisi bir saldırı yüzeyi)
meta-security	policy about policy
guardrail for guardrails	
watching the watchers	(Quis custodiet ipsos custodes)

Bu son öbek obsession tartışmasının kapanışını verir: obsession'ın son aşaması genellikle burada başlar. Kontrolü denetleyen kontrol katmanı, kendisi denetlenmeyen yeni bir saldırı yüzeyi olarak sisteme eklenir.

Askerî ve İstihbarat Kökenli Terminoloji

X-SEC Serisi

COMSEC	communications security
OPSEC	operations security
PERSEC	personnel security
PHYSEC	physical security
TRANSEC	transmission security
SIGSEC	signals security
EMSEC	emissions security (TEMPEST)
COMPUSEC	computer security
INFOSEC	information security
NETSEC	network security
CRYPTOSEC	cryptographic security

Eşlik Eden Doktrin Terimleri

classification / declassification	compartmented information
-----------------------------------	---------------------------

SCI (sensitive compartmented info)	SAP (special access program)
need-to-know	two-person integrity
TEMPEST	red/black separation
air gap	cross-domain solution
data diode	one-way transfer
Bell-LaPadula (gizlilik)	Biba (bütünlük)
no read up / no write down	no read down / no write up
mandatory access control (MAC)	discretionary access control (DAC)
multilevel security (MLS)	multi-independent-levels (MILS)

Emniyet (Safety) Alanından Ödünç Alınanlar

functional safety	SIL (safety integrity level)
ASIL (otomotiv)	DAL (havacılık)
hazard analysis	HAZOP
FMEA / FMECA	fault tree analysis
STPA / STAMP	bow-tie analysis
safety case	assurance case
safety envelope	operational design domain

Dayanıklılık Ekseni

cyber resilience	operational resilience
business continuity (BCP)	disaster recovery (DR)
RTO / RPO	MTTD / MTTR / MTBF
graceful degradation	brownout / load shedding
failover / failback	hot / warm / cold standby
chaos engineering	game day
tabletop exercise	fire drill

Aktör ve Motivasyon Adları

threat actor	threat group / APT
nation-state actor	hactivist
cybercriminal	script kiddie
insider threat	disgruntled insider
initial access broker	ransomware-as-a-service
red team / blue team	purple team
white hat / black hat / grey hat	
bug bounty hunter	security researcher

Ekonomik ve Piyasa Kalıpları

X-as-a-Service:	RaaS, PhaaS, MaaS, CaaS, AaaS
crimeware	exploit broker
vulnerability market	cyber insurance

attack economics	work factor
cost to attack / cost to defend	
asymmetric warfare	defender's dilemma
attacker's advantage	(savunan her deliği, saldıran bir deliği bulmalı)

Diğer Alanlardan Gelen İzomorf Kavramlar

Aşağıdaki kavramlarda “security” sözcüğü geçmez, ancak aynı yapıyı taşırlar.

immünoloji	-> self/non-self ayrımı, bağışıklık hafızası, otoimmünite (otoimmünite = security obsession'ın biyolojik karşılığı)
epidemioloji	-> sürü bağışıklığı, R0, karantina, temas takibi
ekoloji	-> monokültür kırılabilirliği, tür çeşitliliği (yazılım monokültürü = tek CVE'nin tüm filoyu düşürmesi)
finans	-> hedging, portföy çeşitlendirme, stres testi, sermaye tamponu
hukuk	-> masumiyet karinesi vs. ihtiyat ilkesi, ispat yükü
şehirçilik	-> CPTED (tasarımla suç önleme), doğal gözetim, savunulabilir alan
oyun teorisi	-> asimetrik oyun, Stackelberg oyunu, saldıran-savunan dengesi

Türkçe Karşılıklar

Türkçe literatürde oturmuş terimler aşağıdadır.

en az yetki ilkesi	derinlemesine savunma
saldırı yüzeyi	tehdit modelleme
sıfır güven	güvenlik duruşu
güvenlik gösterisi	bilgi güvenliği
sızma testi	zafiyet taraması
olay müdahale	iş sürekliliği
güvenli varsayılan	güvenlik açığı
yetki yükseltme	yatay hareket

Çalışmanın Yöntemsel Adlandırması

Bu çalışmanın birden fazla adı mevcuttur; hangisinin uygun olduğu çıktının kullanım amacına bağlıdır.

Aday Adlandırmalar

- **Kavram haritalama (concept mapping):** Novak'ın terimi. Bir alanın kavramlarını çıkarıp aralarındaki ilişkileri açık hâle getirmek. Bu çalışmada ilişkiler çoğunlukla örtük kalmış, liste biçimi baskın olmuştur.
- **Terminoloji çıkarımı (domain vocabulary extraction):** Bir alanın söz varlığının sistematik olarak toplanması. Özellikle kalıp bazı ilerlenen aşamalar dikkate alındığında en yakın teknik adlandırmadır.

- **Hafif ontoloji taslağı (lightweight ontology):** Terimlerin sınıflara ayrılıp (duruş, ilke, alan, aktör, ölçüm, anti-örüntü) aralarında ilişki tipleri tanımlanması. Kapanışta bu altı eksene indirgenmesiyle fiilen bu noktaya varılmış, ancak formel bir yapı kurulmamıştır.
- **Semantik alan analizi (lexical field analysis):** Dilbilim kökenli yaklaşım. Bir kavramın etrafındaki sözcük öbeğinin, karşıtlarının ve derece ifadelerinin haritalanması. *paranoia* → *vigilance* → *complacency* → *negligence* spektrumu bu kategoriye girer.
- **Taksonomi inşası:** Gerçek taksonomi tekil hiyerarşi ve karşılıklı dışlayıcılık gerektirir; buradaki listeler kesişimli olduğundan tam karşılık değildir.

İzlenen Süreç

1. Kavramsal ayrım (security-first <-> obsession)
2. Alan taraması (komşu kavramlar)
3. Kalıp çıkarımı (morfolojik: security-X, X-secure, X-first)
4. Doygunluk (yeni terim gelmemeye başlaması)
5. Eksen indirgeme (altı boyuta toplama)

Bu dizi, nitel araştırmadaki *açık kodlama* → *eksensel kodlama* sırasının aynısıdır (Grounded Theory). Önce tüm veri toplanır, ardından kategorilere ayrılır, sonrasında kategoriler arası eksen kurulur. Dördüncü adımdaki tekrar hissi, literatürdeki adıyla *teorik doygunluktur* (theoretical saturation).

Yöntemin Kendi Sınırı

Morfolojik üretim (*security-* öneki artı sıfat) belirli bir noktadan sonra var olan terimleri değil, üretilebilir terimleri vermeye başlar. Envanterin geçerliliği tam olarak bu noktada sona erer. Bu sınırın ayırt edilebilir olması, envanterin kendisinden daha değerli bir çıktı olabilir.

Kapanış: Altı Eksen

Kavramsal harita nihai olarak şu eksenlerle kapanmaktadır:

duruş	-> ne zaman
ilke	-> nasıl
alan	-> nerede
aktör	-> kim
ölçüm	-> ne kadar
anti-örüntü	-> nasıl bozulur